



SVKM'S  
**NMIMS**  
Deemed to be UNIVERSITY

MUKESH PATEL SCHOOL OF  
TECHNOLOGY MANAGEMENT  
& ENGINEERING<sup>TM</sup>



# INIT'26

TEAM: PHOENIX | TRACK: CYBERSECURITY | PROJECT: API SENTINEL

# SLIDE 1 : TITLE SLIDE

**TRACK :**  
**Cybersecurity**

**PROBLEM STATEMENT :**

Modern cloud and microservice architectures rely extensively on distributed REST APIs. Traditional WAFs and perimeter firewalls lack runtime context and fail to inspect dynamic request payloads in real time. Consequently, organizations suffer severe data exfiltration, credential abuse, account takeovers, and silent privilege escalation from OWASP API Top 10 vulnerabilities (including SQL injection, BOLA/IDOR object enumeration, sensitive token exposure, and automated brute-force scraping).

**TEAM NAME :**  
**Phoenix**

**IDEA TITLE :**  
**API Sentinel - Autonomous Real-Time API Security, Threat Detection & Zero-Trust Policy Enforcement Platform**

# SLIDE 2 : PROPOSED SOLUTION

## 01. INGESTION & INTERCEPTION

### Non-Invasive Gateway Interceptor

- Transparent HTTP Wrapper: Utilizes `CachedBodyHttpServletRequest` to safely inspect inbound payload bodies without prematurely consuming the downstream stream.
- Full-Spectrum Inspection: Parses and correlates HTTP headers, URI query params, route variables, and JSON payloads simultaneously.
- Zero Disruption: Operates seamlessly as an upstream reverse proxy or embedded servlet filter with under 5ms latency overhead.

## 02. THREAT DETECTION & SCORING

### Multi-Vector Heuristic Engine

- OWASP Top 10 Coverage: Modular detectors scan for SQL Injection, XSS payloads, Credential Abuse, and Sensitive Data Exposure.
- IDOR / BOLA Discovery: Sequential path anomaly detection flags automated resource harvesting and parameter enumeration.
- Dynamic 0-100 Scoring: Weights vector confidence, historical IP reputation, and payload lethality to produce an instant threat score.

## 03. MITIGATION & OBSERVABILITY

### Zero-Trust Policy Enforcement

- Autonomous Response: Instant verdict determination - ALLOWED, RATE\_LIMITED (HTTP 429), or BLOCKED (HTTP 403 Forbidden).
- Perimeter IP Isolation: Dynamically quarantines aggressive IPs at the gateway perimeter before microservices are impacted.
- Real-Time SOC Telemetry: Next.js operations console with live threat feeds, forensic payload audits, and interactive attack simulator.

# SLIDE 3 : TECHNICAL APPROACH

## FRONTEND : SECURITY OPERATIONS CENTER (SOC)

- Stack: Next.js 14 (App Router), React 18, TypeScript, Tailwind CSS, Lucide Icons.
- Live Telemetry: Sub-second telemetry aggregation displaying active threats, request verdicts, risk trends, and endpoints.
- Live Production Deployment: Hosted on Vercel Edge Network at <https://apisentinel-psi.vercel.app>
- Interactive Console: Full audit exploration, policy controls, and offensive attack simulator.

## BACKEND : ZERO-TRUST API SECURITY GATEWAY

- Stack: Java 17, Spring Boot 3.2, Spring Security 6 (Stateless Zero-Trust Filter Chain).
- Resilient Architecture: HikariCP connection pooling, graceful shutdowns, and Actuator health probes.
- Cloud Deployment: Containerized multi-stage Docker build deployed on Render at <https://api-backend-wc8m.onrender.com>
- Performance: Non-blocking in-memory evaluation with under 5ms processing latency per request.

## CORE DETECTION & SCORING PIPELINE

- Interception Filter: Intercepts raw byte streams and constructs thread-safe `ApiRequestContext`.
- Modular Detectors: `InjectionDetector` (SQLi/XSS), `EnumerationDetector` (BOLA), `AuthenticationAbuseDetector`, `RateAbuseDetector`, `SensitiveDataExposureDetector`.
- Scoring Engine: `ThreatScoringEngine` evaluates weighted vector risk into deterministic score (0-100).
- Enforcement Engine: `DefaultPolicyEngine` matches active rules and returns instant verdict.

## PERSISTENCE & MONOREPO CLOUD ARCHITECTURE

- Cloud Database: Managed PostgreSQL database on Render storing security incidents, request audit logs, endpoints, and firewall policies.
- Single GitHub Monorepo: Houses `/backend`, `/frontend`, `/database`, and orchestration in one repo.
- Local Development: `docker-compose.yml` runs complete local MySQL/Spring/Next.js environment.
- Cross-Origin Security: Fine-grained CORS controls securing browser clients and API gateways.

# SLIDE 4 : HOW IT WORKS ? (USER FLOW)

## STEP 1 : Inbound Request Ingestion

Client or attacker issues HTTP API call (GET, POST, PUT, DELETE) targeting protected microservice endpoints.

## STEP 2 : Deep Payload Caching

TrafficInterceptionFilter wraps stream using CachedBodyHttpServletRequest and extracts headers, URI parameters, and body.

## STEP 3 : Multi-Vector Heuristics

Engine executes parallel modular detectors scanning for SQL injection tokens, XSS scripts, token leakage, and BOLA enumeration patterns.

## STEP 4 : Dynamic Threat Scoring

ThreatScoringEngine aggregates detection signals and evaluates a composite 0-100 severity score with recommended action.

## STEP 5 : Automated Policy Action

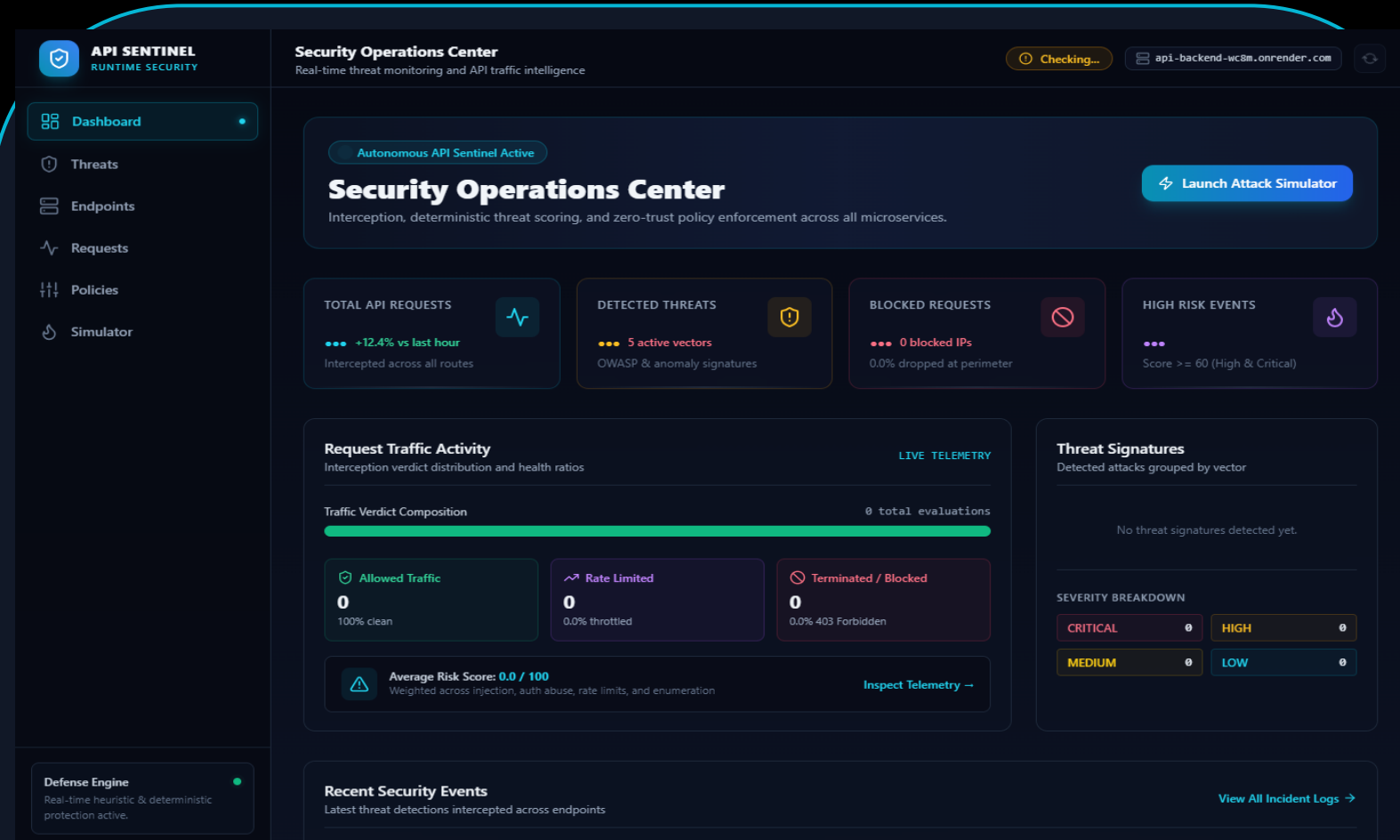
PolicyEngine decides verdict: ALLOWED (forwarded to downstream handler), RATE\_LIMITED (HTTP 429), or BLOCKED (HTTP 403 Forbidden).

## STEP 6 : Forensic Log & SOC Update

Request audit details and forensic evidence are persisted to PostgreSQL and pushed live to the SOC Dashboard in real time.

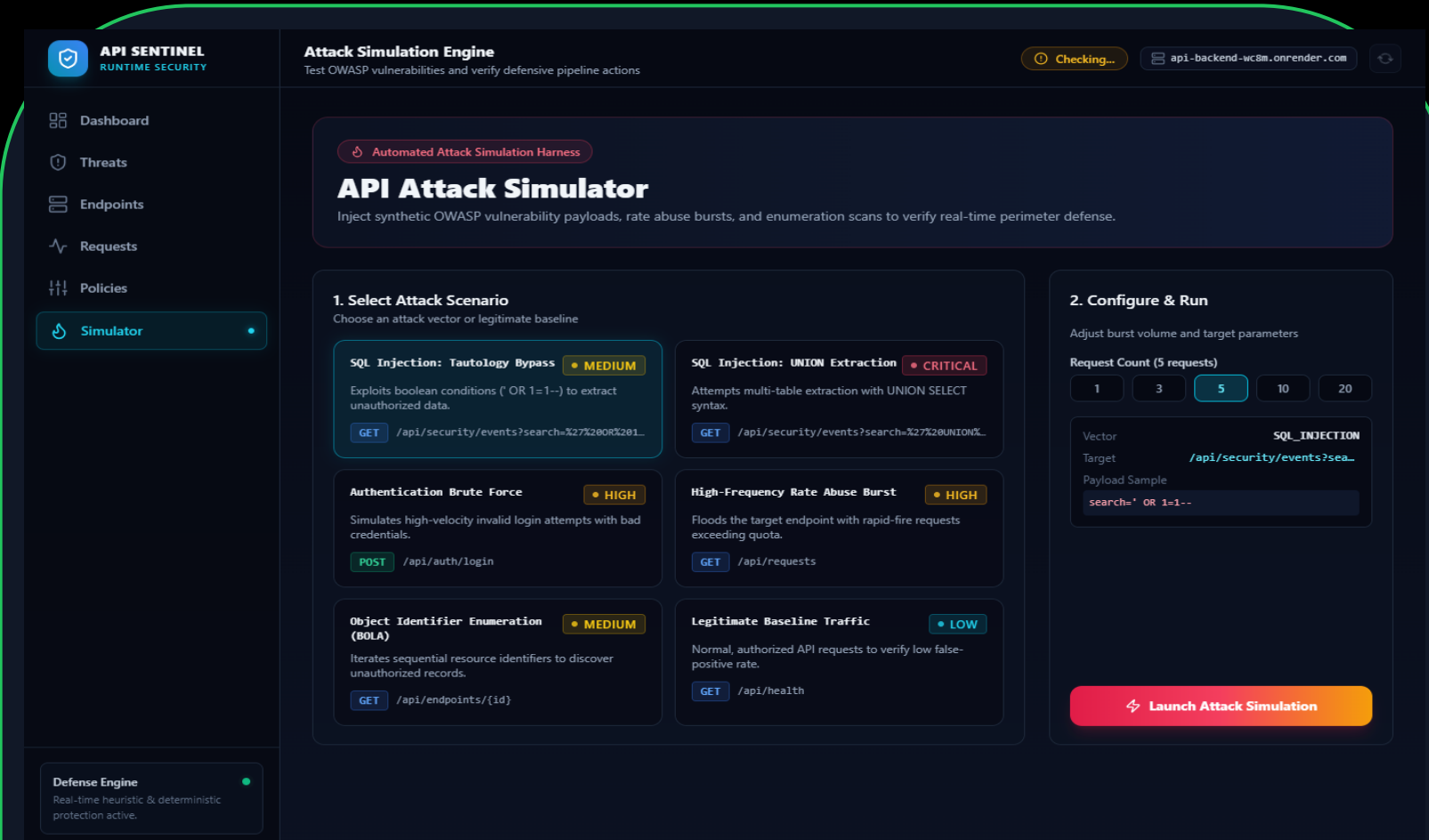


# SLIDE 5 : PROJECT SNAPSHOTS



## Security Operations Center (SOC) Dashboard

Real-time traffic health ratios, threat severity composition, average risk scores, and live incident telemetry feed connected to Render PostgreSQL.



## Interactive Attack Simulator & Forensic Inspector

Simulates OWASP attack vectors (SQLi, IDOR/BOLA, Brute Force) against live APIs; verifies instantaneous detection, threat scoring, and gateway mitigation.

LIVE DEPLOYED DEMO LINKS (CLICKABLE IN SUBMISSION) :

Frontend: <https://apisentinel-psi.vercel.app> | Backend API: <https://api-backend-wc8m.onrender.com> | GitHub: <https://github.com/Yokeshwaran03-2005/API-SENTINEL>

# SLIDE 6 : FEASIBILITY/VIABILITY AND IMPACT

## TECHNICAL FEASIBILITY & CLOUD-NATIVE SCALABILITY

- High Efficiency: Sub-5ms latency overhead per evaluation ensures near-zero performance degradation for high-traffic APIs.
- Flexible Deployment: Can run as an independent API Gateway reverse proxy, a sidecar container in Kubernetes pods, or an embedded Spring filter.
- Containerized & Portable: Packaged via multi-stage Docker builds; runs on AWS, Render, Google Cloud, or on-premise infrastructure.

## COMMERCIAL VIABILITY & MARKET ADOPTION

- Exploding Market Demand: API attacks surged over 400% YoY, rendering standard IP-based firewalls obsolete against application-layer abuse.
- Cost-Effective Alternative: Replaces bulky multi-thousand dollar enterprise WAF appliances with lightweight, software-defined API defense.
- Sector Relevance: Direct applicability to Fintech (PSD2/Open Banking), Healthcare (HIPAA), E-Commerce, and SaaS API providers.

## MEASURABLE IMPACT & SOC EMPOWERMENT

- MTTD & MTTR Drastically Reduced: Threat detection and automated mitigation drop from hours of manual log triage to under 100 milliseconds.
- 100% Autonomous Perimeter Defense: Prevents data exfiltration and unauthorized resource tampering before reaching backend services.
- Full Compliance Trail: Immutable audit logs in PostgreSQL simplify regulatory audits (SOC2 Type II, ISO 27001, and GDPR).

# SLIDE 7 : REFERENCES

## INDUSTRY STANDARDS & RESEARCH

- OWASP API Security Top 10 (2023)  
Vulnerability standards covering BOLA, Broken Authentication, Object Property Level Authorization, and Unrestricted Resource Consumption.
- NIST Special Publication 800-207  
Zero Trust Architecture guidelines emphasizing per-request authentication, dynamic policy evaluation, and perimeter isolation.
- MITRE ATT&CK Framework  
Tactics, Techniques, and Procedures (TTPs) for Web Application and API exploitation vectors.

## TECHNOLOGY FRAMEWORKS & SPECS

- Spring Framework 6 & Spring Boot 3.2  
High-performance enterprise Java reactive and servlet filter architecture; Spring Data JPA and Spring Security.
- Next.js 14 App Router & React 18  
Modern server-rendered web application framework, edge runtime routing, and Tailwind CSS design system.
- PostgreSQL 16 & HikariCP  
ACID-compliant relational persistence, JSONB document querying, and ultra-low latency connection pooling.

## PROJECT LINKS & DEPLOYMENTS

- GitHub Monorepo:  
<https://github.com/Yokeshwaran03-2005/API-SENTINEL>  
Complete source code, Docker configs, and setup documentation.
- Live Frontend SOC Dashboard:  
<https://apisentinel-psi.vercel.app>  
Production deployment on Vercel.
- Live Backend API & Health Check:  
<https://api-backend-wc8m.onrender.com/api/health>  
Production deployment on Render.